

1. Introducción

Este reporte describe una vulnerabilidad de **SQL Injection** encontrada en la aplicación DVWA. La prueba fue realizada en un entorno controlado de laboratorio, usando una máquina Debian.

El objetivo fue comprobar si el campo **User ID** era vulnerable a inyección SQL.

2. Descripción de la vulnerabilidad

Se encontró una vulnerabilidad de **SQL Injection** en el campo **User ID** del módulo SQL Injection de DVWA.

Esta vulnerabilidad ocurre porque la aplicación no valida correctamente los datos que ingresa el usuario. Como consecuencia, es posible modificar la consulta SQL original y obtener información de la base de datos.

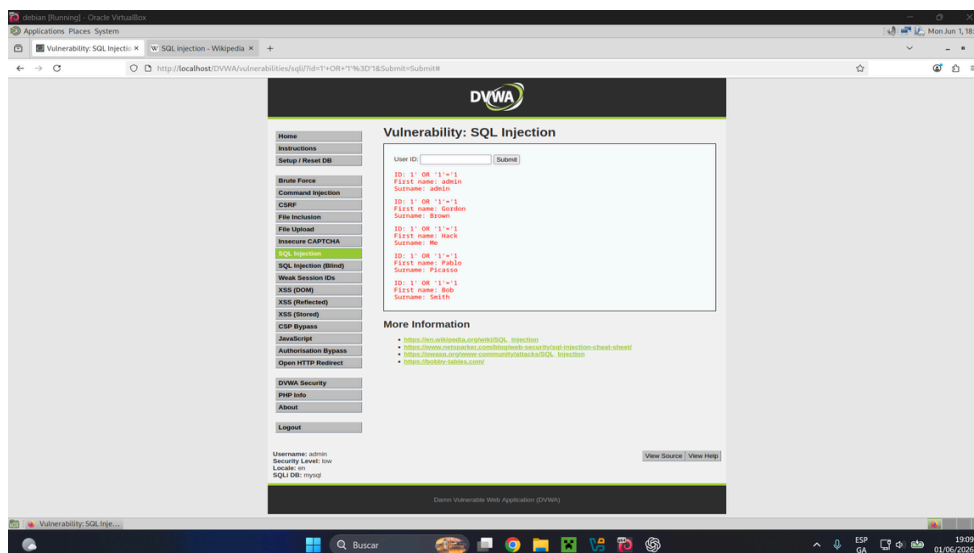
3. Payload utilizado

En el campo **User ID** se ingresó el siguiente payload:

`1' OR '1'='1`

4. Evidencia

Después de ejecutar el payload, DVWA mostró varios usuarios:



5. Impacto

Si esta vulnerabilidad existiera en una aplicación real, un atacante podría:

- Acceder a información privada de usuarios.
- Ver datos almacenados en la base de datos.
- Obtener credenciales u otra información sensible.
- Alterar o eliminar información si tuviera permisos suficientes.

6. Recomendaciones

Para evitar este tipo de vulnerabilidad, se recomienda:

1. Validar correctamente los datos ingresados por el usuario.
2. Usar consultas preparadas o parametrizadas.
3. Limitar los permisos del usuario de la base de datos.
4. No mostrar errores internos de SQL al usuario.
5. Mantener actualizados Apache, PHP, MariaDB y la aplicación.
6. Realizar pruebas de seguridad regularmente.

7. Conclusión

La prueba de SQL Injection fue exitosa. El payload utilizado permitió obtener varios usuarios desde la base de datos de DVWA.